

Name :A.Purusothaman

Reg.no:192421405

Subject:Ethical Hacking

Sub.Code:ITA1407

CO5-ASS1 INDUSTRY BASED QUESTION

CO5 – Security Vulnerability and Exploitation Analysis

1. Windows Domain Network – NULL Sessions, SMB Lateral Movement, RPC, and Weak Shares

Initial-stage compromise

The organization has **150 systems**, and **45%** allow anonymous enumeration through NULL sessions.

$$\begin{aligned} &[\\ &150 \times 0.45 = 67.5 \\ &] \end{aligned}$$

Thus, the expected number of systems exposed during the initial stage is approximately **68 systems**.

Of these systems, **60% are susceptible to SMB-based lateral movement**:

$$\begin{aligned} &[\\ &67.5 \times 0.60 = 40.5 \\ &] \end{aligned}$$

So approximately **41 initially exposed systems** are vulnerable to the specified lateral-movement attack.

Second-stage lateral movement

Each susceptible compromised system can attempt to access **3 additional systems**, with a success probability of **0.3 per attempt**.

Expected successful lateral-movement compromises are:

$$\begin{aligned} &[\\ &40.5 \times 3 \times 0.3 = 36.45 \\ &] \end{aligned}$$

Therefore, approximately **36–37 additional systems** could be compromised during the second stage.

The estimated total number of compromised systems is:

$$\begin{aligned} &[\\ &67.5 + 36.45 = 103.95 \\ &] \end{aligned}$$

or approximately **104 systems**.

Percentage of the network:

$$\begin{aligned} &[\\ &\frac{103.95}{150} \times 100 = 69.3\% \\ &] \end{aligned}$$

The threshold for a large-scale compromise is:

$$\begin{aligned} &[\\ &150 \times 0.70 = 105 \\ &] \end{aligned}$$

The estimated **104 compromised systems are just below the 70% threshold of 105 systems**. Therefore, based strictly on the given expected values, the network does **not quite exceed 70%**, but it is extremely close and should be considered at **very high risk of large-scale compromise**. In a real incident, additional attack paths, repeated attempts, and overlapping trust relationships could easily push the compromise beyond 70%.

Priority for mitigation

NULL sessions should be prioritized first. They expose approximately 45% of the entire network to anonymous enumeration and provide attackers with information useful for identifying users, shares, systems, and other attack targets.

The recommended priority is:

1. **NULL sessions/anonymous enumeration** – largest quantified initial exposure.
2. **Weak SMB/shared-folder permissions** – directly facilitate lateral movement and unauthorized access.
3. **Unnecessary or exposed RPC services** – should be restricted because RPC can provide additional attack surfaces and support lateral movement.

Hence, disabling anonymous NULL sessions and enforcing proper SMB/share permissions should be immediate actions, followed by restricting RPC services to only those required.

2. RPC Exposure – Expected Compromise and Detection Risk

There are **70 systems** exposing RPC services.

The vulnerability scan shows that **40%** are susceptible to known exploits:

$$\begin{aligned} &[\\ &70 \times 0.40 = 28 \\ &] \end{aligned}$$

Therefore, the attacker has **28 potentially vulnerable systems**.

The probability of successful exploitation is **0.5**:

$$\begin{aligned} &[\\ &28 \times 0.5 = 14 \\ &] \end{aligned}$$

Thus, the expected number of successfully compromised systems is **14**.

Expected detection alerts

Each exploitation attempt has a **0.25 probability of detection**. Assuming one attempt is made against each of the 28 vulnerable systems:

$$\begin{aligned} &[\\ &28 \times 0.25 = 7 \\ &] \end{aligned}$$

Therefore, approximately **7 detection alerts** are expected.

The expected results are:

Metric	Expected value
RPC-exposed systems	70
Vulnerable systems	28
Successful compromises	14
Expected detection alerts	7

Stealth evaluation

An attacker attempting to remain stealthy would need to consider the relatively high probability of detection. A direct exploitation campaign involves **28 attempts**, with an expected **7 alerts**. This means approximately one quarter of the exploitation attempts may trigger detection.

Although 14 successful compromises could be significant, generating around seven alerts could rapidly attract the security team's attention and cause the attacker to lose access or have their activity investigated.

Therefore, a stealth-oriented attacker would likely **avoid aggressive exploitation of all vulnerable RPC systems** and consider alternative strategies such as credential abuse, phishing, exploitation of less-monitored services, or other lower-noise techniques.

From the defender's perspective, the results also demonstrate that the IDS provides useful detection coverage, but RPC exposure should still be reduced by restricting unnecessary RPC services and applying security patches.

3. Cloud Linux Server – Internet-Facing Services and Weak File Permissions

The four critical services have independent vulnerability probabilities of:

- ($P_1=0.30$)
- ($P_2=0.20$)
- ($P_3=0.25$)
- ($P_4=0.15$)

Probability that at least one service is vulnerable

It is easier to calculate the probability that **none** of the services are vulnerable:

$$[P(\text{none}) = (1-0.30)(1-0.20)(1-0.25)(1-0.15)]$$

$$[= 0.70 \times 0.80 \times 0.75 \times 0.85]$$

$$[= 0.357]$$

Therefore:

$$[P(\text{at least one vulnerable}) = 1 - 0.357]$$

$$[= \boxed{0.643}]$$

Thus, there is a **64.3% probability** that at least one of the four services is vulnerable and provides an exploitation opportunity.

Probability of full system compromise

Once initial access is obtained, weak file permissions can be exploited for privilege escalation with probability **0.5**.

Therefore:

$P(\text{initial access}) \times P(\text{privilege escalation})$

]

[

$= 0.643 \times 0.5$

]

[

$= \boxed{0.3215}$

]

Thus, the overall probability of full system compromise is approximately **32.15%**.

Evaluation of file-permission mitigation

Strengthening file permissions would substantially reduce the **privilege-escalation stage**, because the probability of exploiting weak permissions would fall from 0.5.

However, it would **not eliminate the initial attack surface**. There is still a **64.3% probability** that at least one exposed service is vulnerable.

Therefore, strengthening file permissions alone is **not sufficient**. It is an important defense-in-depth measure, but it should be combined with:

- Regular patching of internet-facing services.
- Removal or restriction of unnecessary services.
- Network segmentation and firewall controls.
- Least-privilege access.
- Secure file and directory permissions.
- Continuous vulnerability monitoring.

The key point is that file-permission hardening reduces the probability of turning initial access into full compromise, but **service vulnerabilities remain the primary entry-point risk**.

4. NFS – Unauthorized Access and Root Privilege Escalation

The three subnets have unauthorized-access probabilities of **0.4, 0.3, and 0.2**.

Probability that at least one subnet gains unauthorized access

The probability that none of the subnets gains access is:

$$[(1-0.4)(1-0.3)(1-0.2)$$

$$[=0.6\times0.7\times0.8$$

$$[=0.336$$

Therefore:

$$[P(\text{at least one access})=1-0.336$$

$$[=\boxed{0.664}$$

Thus, there is a **66.4% probability** that at least one subnet will successfully obtain unauthorized access to the NFS share.

Probability of complete compromise

Privilege escalation to root has probability **0.7** after NFS access.

Therefore:

$$[P(\text{complete compromise})$$

$$[=0.664\times0.7$$

$$[=\boxed{0.4648}$$

Thus, the overall probability of complete compromise is approximately **46.48%**.

Effectiveness of restricting NFS access to one subnet

Restricting access to a single trusted subnet would substantially reduce the attack surface.

If the subnet with the lowest unauthorized-access probability (**0.2**) is selected:

$$[P(\text{complete compromise})=0.2\times0.7$$

$$[\\ =\boxed{0.14} \\]$$

This reduces the complete-compromise probability from **46.48% to 14%**.

For comparison:

- Restricting to subnet 1: $(0.4 \times 0.7 = 28\%)$
- Restricting to subnet 2: $(0.3 \times 0.7 = 21\%)$
- Restricting to subnet 3: $(0.2 \times 0.7 = 14\%)$

Therefore, **restricting NFS access to a single appropriately trusted subnet is an effective mitigation**, especially when the lowest-risk subnet can be selected.

However, NFS access controls should not be the only defense. Strong authentication, proper export configuration, least privilege, root-squashing, and network segmentation should also be implemented.

5. E-Commerce Platform – SQL Injection and Data Exposure

The database contains **50,000 user records**.

A SQL injection attack can extract **500 records per second**, but the application firewall blocks the attack after **40 seconds**.

Number of records extracted

$$[\\ 500 \times 40 = 20,000 \\]$$

Therefore, the attacker can extract approximately:

$$[\\ \boxed{20,000 \text{ records}} \\]$$

before being blocked.

Percentage of total data compromised

$$[\\ \frac{20,000}{50,000} \times 100 \\]$$

$$[\\ =\boxed{40\%} \\]$$

Thus, **40% of the entire database** could be compromised before the firewall responds.

Sensitive records exposed

Sensitive records constitute **30%** of the database:

$$\begin{aligned} &[\\ &50,000 \times 0.30 = 15,000 \\ &] \end{aligned}$$

Assuming the extracted records have the same distribution as the overall database, the number of sensitive records exposed is:

$$\begin{aligned} &[\\ &20,000 \times 0.30 = 6,000 \\ &] \end{aligned}$$

Therefore, approximately:

$$\begin{aligned} &[\\ &\boxed{6,000 \text{ sensitive records}} \\ &] \end{aligned}$$

could be exposed.

Severity and effectiveness of the detection mechanism

The breach is **highly serious** because the attacker can obtain **20,000 records, or 40% of the entire database, in only 40 seconds**. This includes an estimated **6,000 sensitive records**.

Although the application firewall eventually detects and blocks the attack, its response is not sufficient to protect critical data because a very large quantity of information can be extracted before blocking occurs.

The organization should therefore use multiple layers of protection, including:

- Parameterized queries/prepared statements to prevent SQL injection.
- Input validation and secure coding practices.
- Database accounts with least privilege.
- Web application firewalls with faster detection and blocking.
- Database activity monitoring.
- Rate limiting and query controls.
- Regular penetration testing and vulnerability assessments.

Therefore, the existing detection mechanism is **useful but insufficient by itself**. Preventing SQL injection at the application layer is substantially more effective than allowing the attack to proceed for 40 seconds and relying solely on post-detection blocking.

